

Meeting Notes

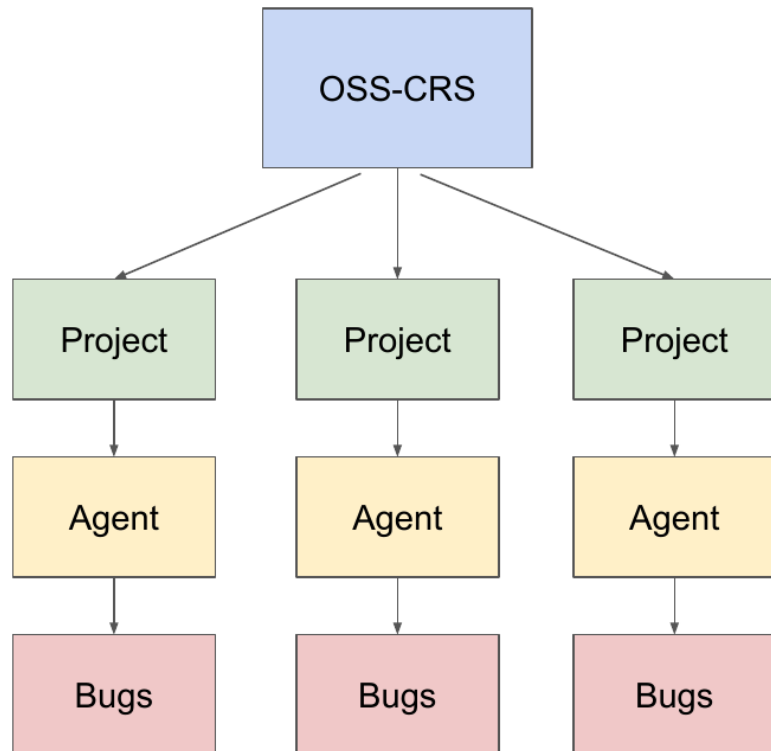
OpenSSF Cyber Reasoning Systems Special Interest Group

2026-07-13

Agenda

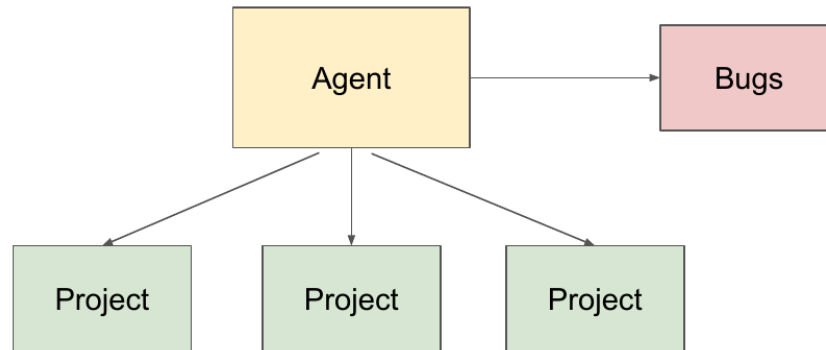
After running a bug-finding campaign both inside and outside of OSS-CRS, I would like to share some thoughts.

OSS-CRS Deployment Workflow



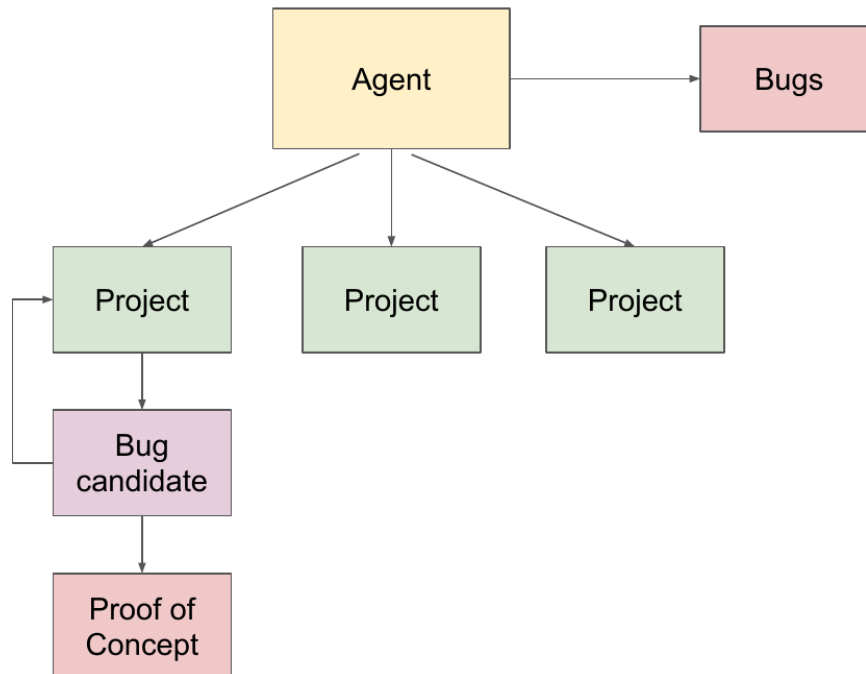
Agentic Bug-Finding

For security researchers, they tend to look for a particular bug across multiple projects.



Agentic Bug-Finding

Internally, the agent searches for code that looks buggy (according to vulnerable patterns), then tries to create a proof-of-concept to prove the vulnerability.



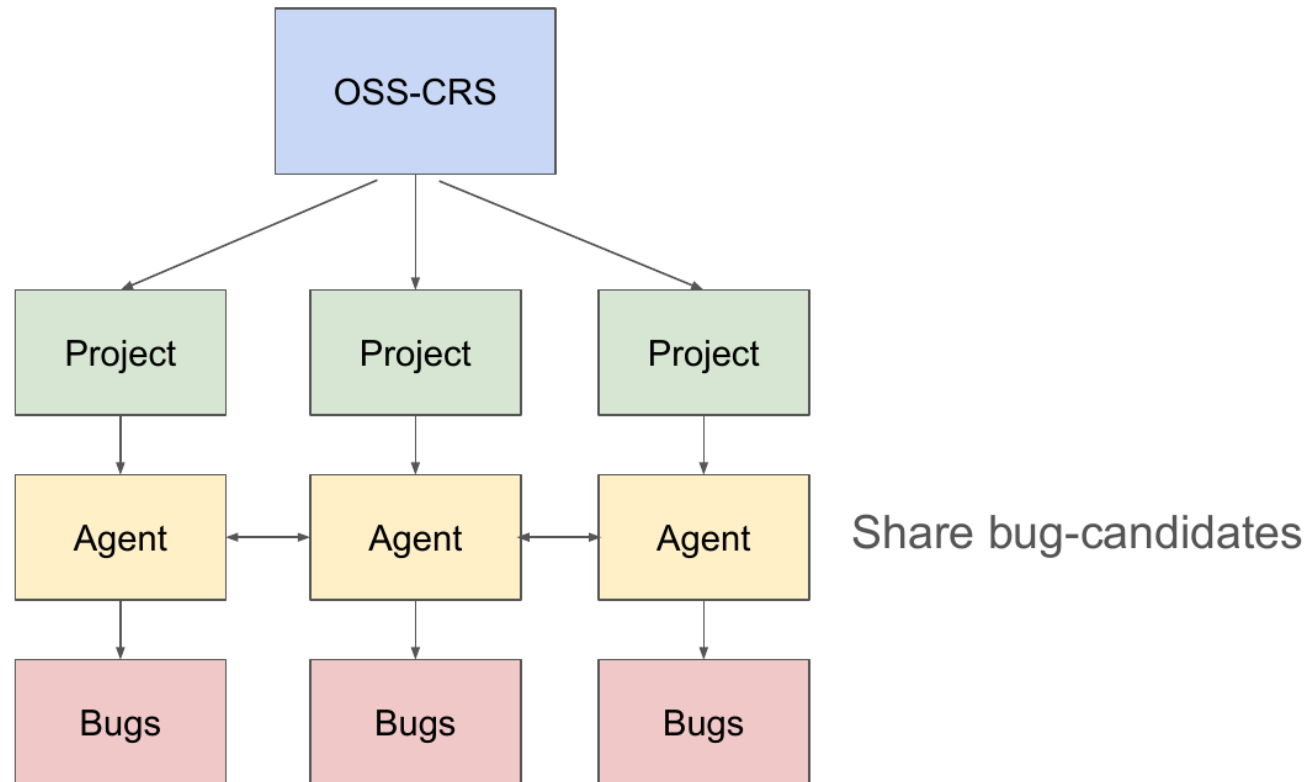
Gaps for OSS-CRS

Compared to running an agent that checks out many projects searching for domain specific bugs, OSS-CRS lacks:

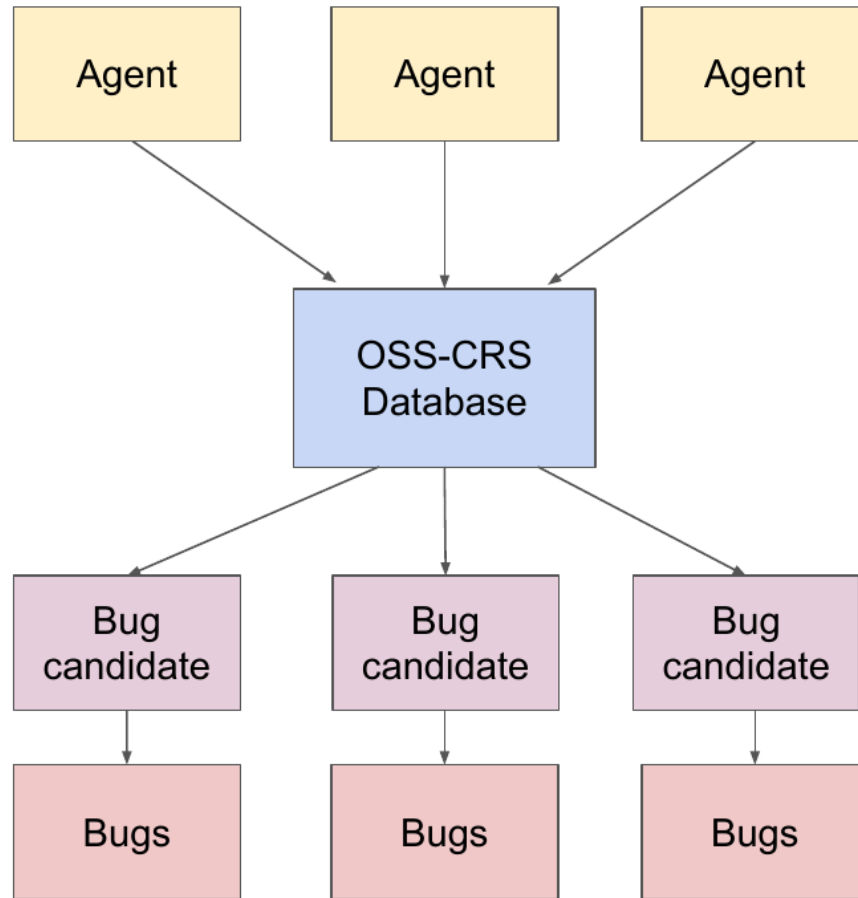
- cross-project knowledge
- resumable context and campaigns
- automatic target selection

Proposal: Rich Bug-Candidate Interface

[GH Issue 310](#)

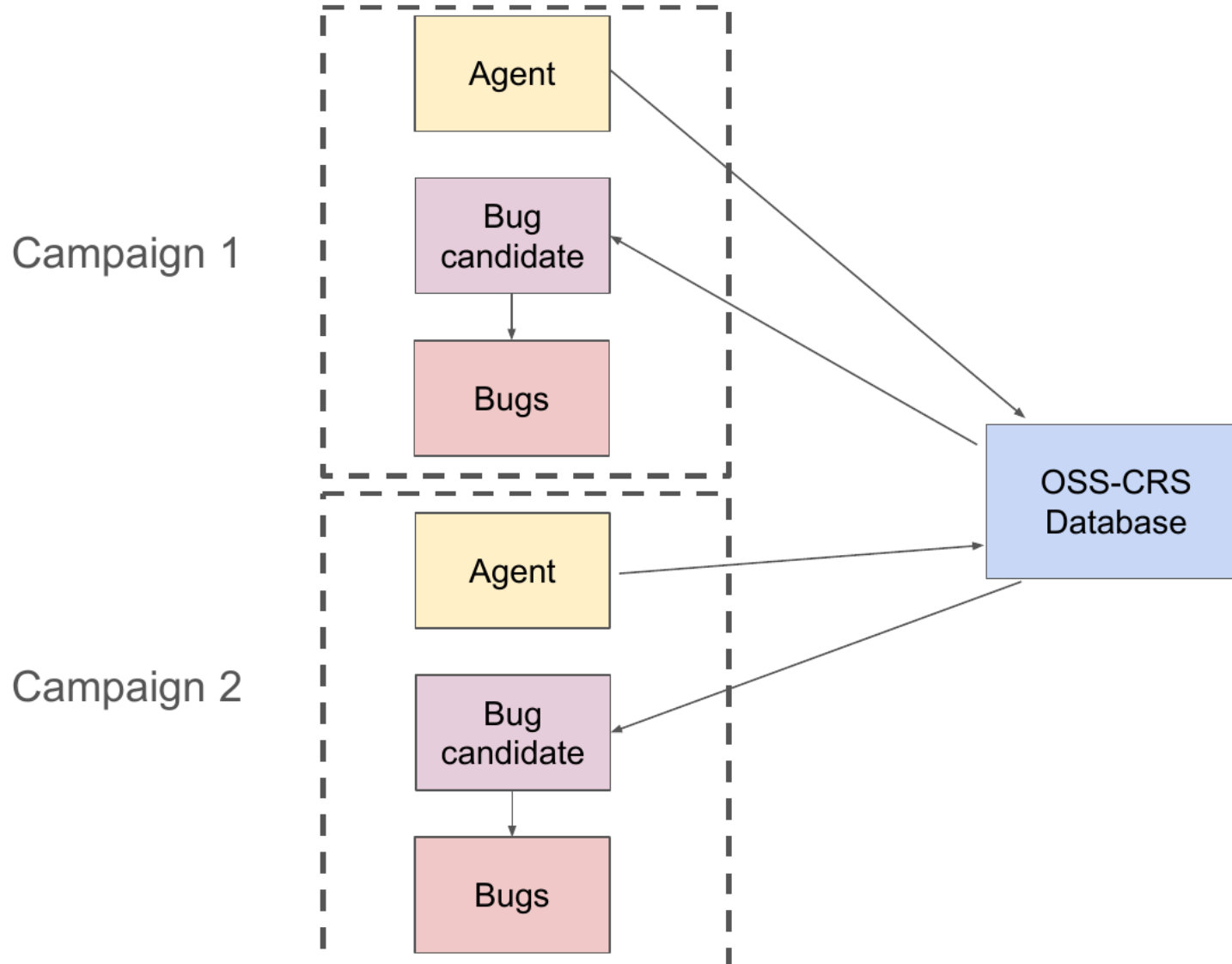


Proposal: Rich Bug-Candidate Interface

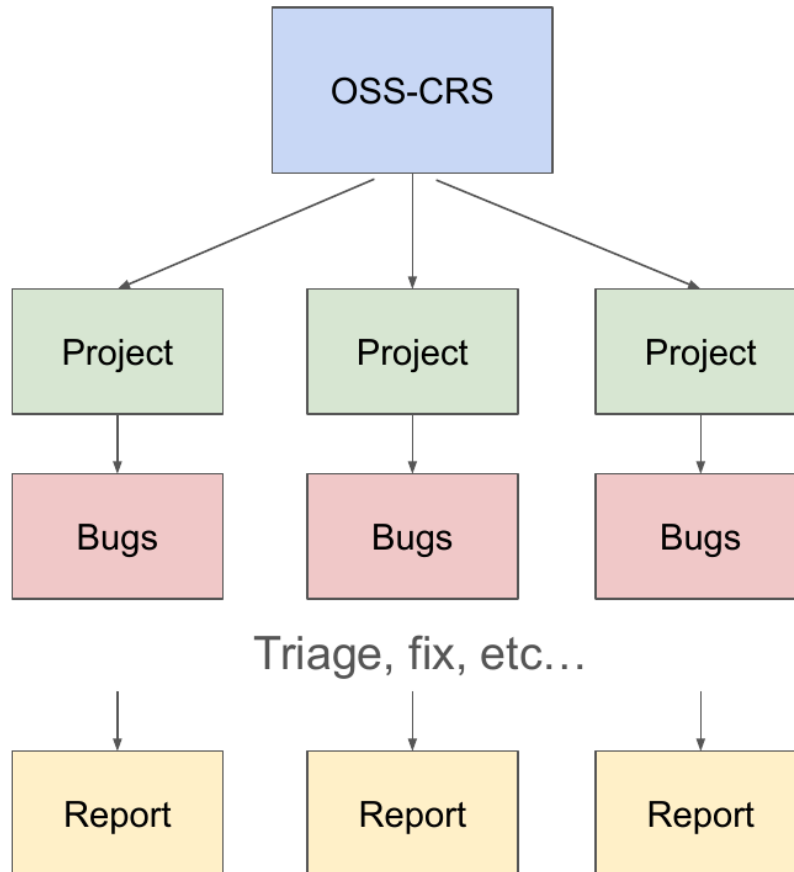


Agents can both
publish and consume
bug candidates

Publish: “found interesting
location”
Consume: “turn interesting
location into proof of concept”



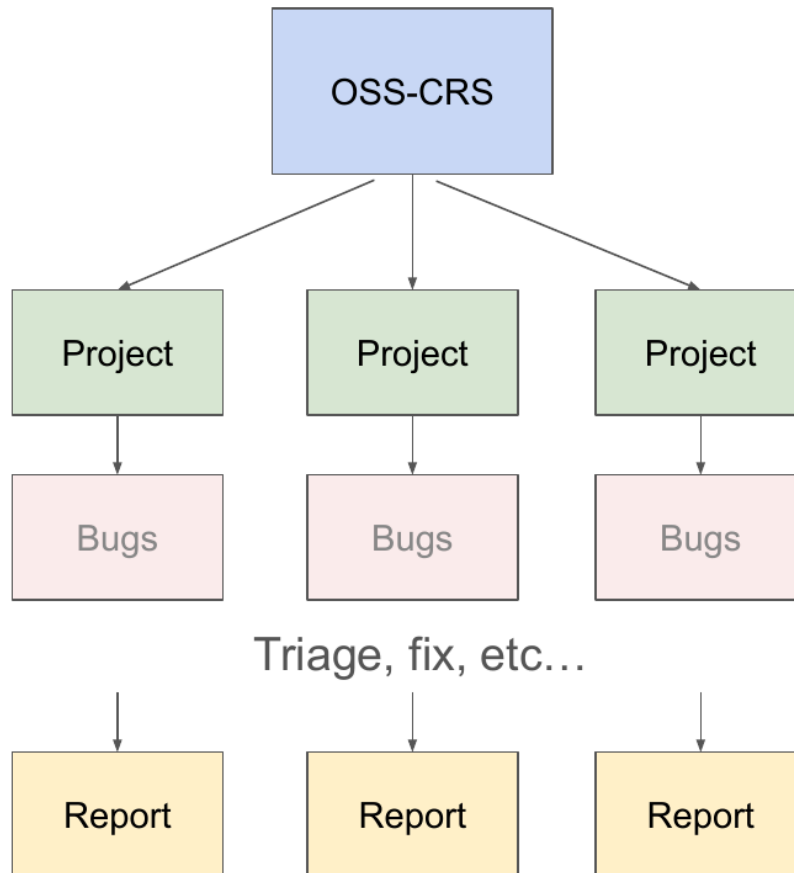
OSS-CRS: Report Generation



Report:

- Reproducer
 - Minimize harness + input
- Bug description
- Suggested fix
 - Bug-fixing CRS

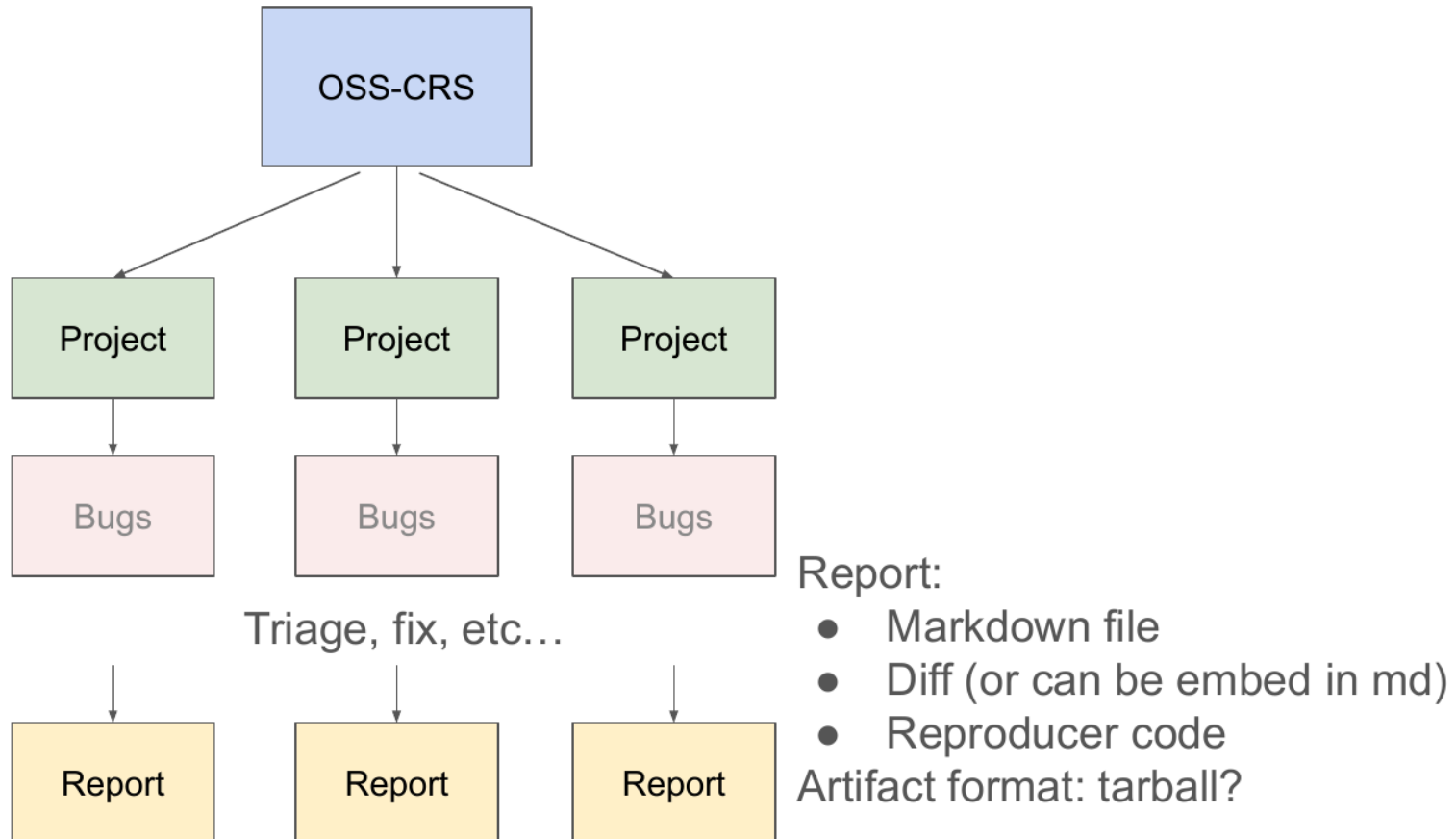
OSS-CRS: Report Generation Workflow



Report:

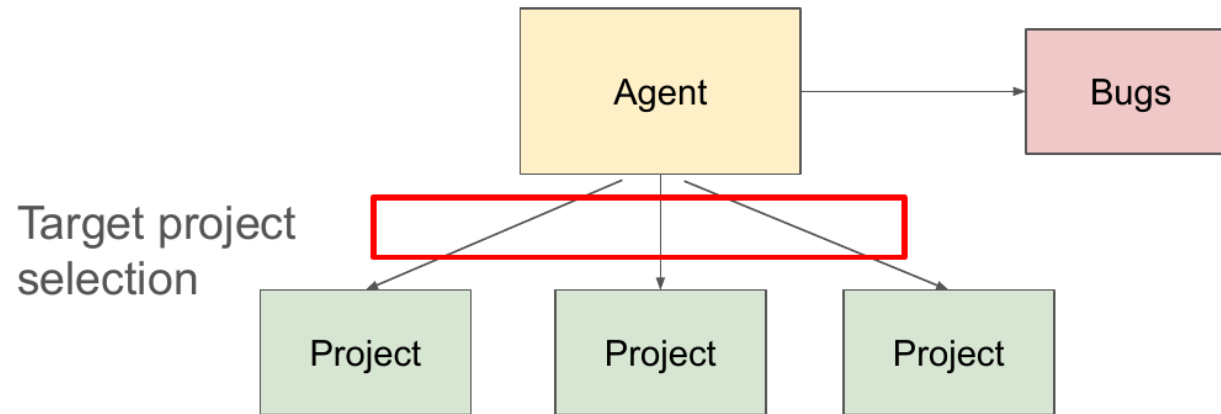
- Reproducer
 - Minimize harness + input
 - PoV may be unnecessary in workflow
- Bug description
- Suggested fix
 - Bug-fixing CRS

OSS-CRS: Report Generation Artifacts



OSS-CRS: Report Generation Artifacts

Open question on whether it's in scope of OSS-CRS.



Q&A / Discussion

Refer to Cyber Reasoning Systems bi-weekly meeting notes.